# Izvještaj o inspekciji koda – BentoLab (Grupa1-Tim1)

## 1. Opseg i postupak

- Inspektovani projekat: BentoLab (tim Grupa1-Tim1), grana Inspekcija-koda.
- Veličina koda: oko 5.500 linija C# i Razor koda bez migracija (Controllers 1.669, Models 255, Views 3.510, Program.cs 56).
- Detaljno pregledano: Controllers, Models, Program.cs, appsettings.json i csproj (oko 2.000 linija). Views su većinom generisani CRUD pa su pregledani uzorkom. Migracije su izuzete jer su generisan kod.
- Ozbiljnost je određena skalom iz predavanja 2: 5 kritično, 4 visoko, 3 srednje, 2 nisko, 1 minorno.
- Nalazi su prijavljeni kao komentari na kod i issue kartice. Svaki sadrži ozbiljnost i stavku check liste.

## 2. Rezultati inspekcije

Ukupno je prijavljeno 19 nalaza: 14 komentara na kod i 5 issue kartica.

| Ozbiljnost | Broj nalaza | Nalazi |
|---|---|---|
| 5 kritično | 3 | N5, N7, N15 |
| 4 visoko | 7 | N9, N10, N11, N12, N13, N14, N16 |
| 3 srednje | 3 | N1, N2, N8 |
| 2 nisko | 5 | N3, N6, N17, N18, N19 |
| 1 minorno | 1 | N4 |

| ID | Lokacija | Nalaz | Oz. | Stavka check liste | Recenzent |
|---|---|---|---|---|---|
| N1 | Views/Shared/_LoginPartial.cshtml:19 | Odjava šalje GET bez antiforgery tokena (CSRF) | 3 | Sigurnosna: Kontrola pristupa | Sunita |
| N2 | Program.cs:16 | Potvrda naloga mailom je uključena, a servis za slanje nije povezan | 3 | Opšta: Defanzivno programiranje | Sunita |
| N3 | appsettings.json:11 | AllowedHosts je * | 2 | Sigurnosna: konfiguracija | Sunita |

| ID | Lokacija | Nalaz | Oz. | Stavka check liste | Recenzent |
|---|---|---|---|---|---|
| N4 | Views/Shared/Error.cshtml:16 | Razvojni tekst prikazan krajnjem korisniku | 1 | Sigurnosna: Upravljanje greškama | Rasim |
| N5 | AdminNarudzbeController.cs:12 | Nema autorizacije, svako može mijenjati status narudžbi | 5 | Sigurnosna: Kontrola pristupa | Rasim |
| N6 | AdminNarudzbeController.cs:56 | Enum.TryParse prihvata nepostojeće statuse | 2 | Sigurnosna: Validacija unosa | Sunita |
| N7 | KorisniksController.cs:57 | Bind uključuje Uloga bez autorizacije (over-posting) | 5 | Sigurnosna: Kontrola pristupa | Sunita |
| N8 | HomeController.cs:55 | POST akcije bez ValidateAntiForgeryToken | 3 | Sigurnosna: Kontrola pristupa | Mehmed |
| N9 | TortasController.cs:104 | Cijenu torte određuje klijent | 4 | Sigurnosna: Validacija unosa | Mehmed |
| N10 | NarudzbasController.cs:77 | Narudžba se pripisuje pogrešnom korisniku | 4 | Opšta: Defanzivno programiranje | Sunita |
| N11 | KorpasController.cs:94 | Podaci o dostavi se ne spremaju, nema autorizacije | 4 | Opšta: Defanzivno programiranje | Sunita |
| N12 | EmailService.cs:89 | SMTP kredencijali u izvornom kodu | 4 | Sigurnosna: Upravljanje tajnama | Hana |
| N13 | KameraController.cs:35 | Slanje fajlova bez prijave i bez provjere sadržaja | 4 | Sigurnosna: Validacija unosa | Hana |
| N14 | Models/Korisnik.cs:14 | NotMapped polja se koriste u upitima, Lozinka u modelu | 4 | Opšta: Struktura | Sunita |
| N15 | Issue 1 | Kontroleri bez [Authorize] | 5 | Sigurnosna: Kontrola pristupa | Sunita |
| N16 | Issue 2 | Nedostaju wwwroot i pogledi | 4 | Opšta: Struktura | Sunita |
| N17 | Issue 4 | Dupli i neiskorišteni fajlovi | 2 | Opšta: Struktura | Rasim |
| N18 | Issue 5 | Nema .gitignore | 2 | Opšta: Struktura | Sunita |
| N19 | Issue 6 | README je prazan | 2 | Opšta: Struktura | Mehmed |

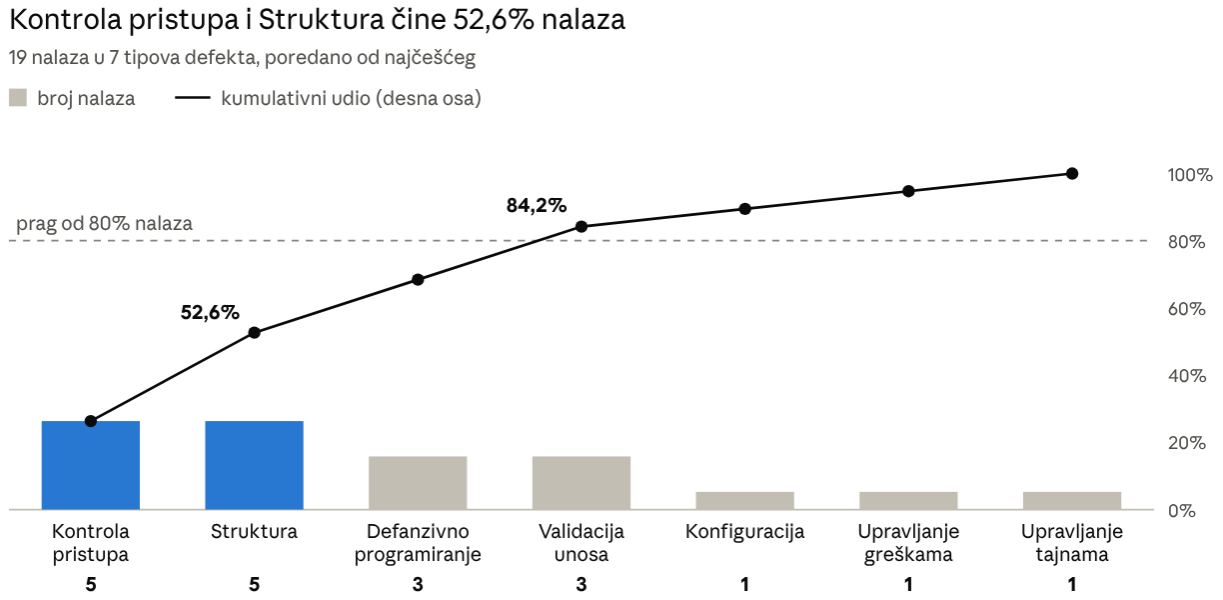
Nalazi N5 i N7 su konkretni primjeri opšteg problema iz N15.

# 3. Pareto analiza defekata

Tip defekta je stavka check liste u koju nalaz spada. Svaki nalaz je dodijeljen jednoj stavci.

| Tip defekta | Broj | Udio | Kumulativno |
|---|---|---|---|
| Kontrola pristupa | 5 | 26,3% | 26,3% |
| Struktura | 5 | 26,3% | 52,6% |
| Defanzivno programiranje | 3 | 15,8% | 68,4% |

| Tip defekta | Broj | Udio | Kumulativno |
|---|---|---|---|
| Validacija unosa | 3 | 15,8% | 84,2% |
| Konfiguracija | 1 | 5,3% | 89,5% |
| Upravljanje greškama | 1 | 5,3% | 94,7% |
| Upravljanje tajnama | 1 | 5,3% | 100% |




Izvor: tabela nalaza N1–N19 ovog izvještaja, tip defekta = stavka check liste

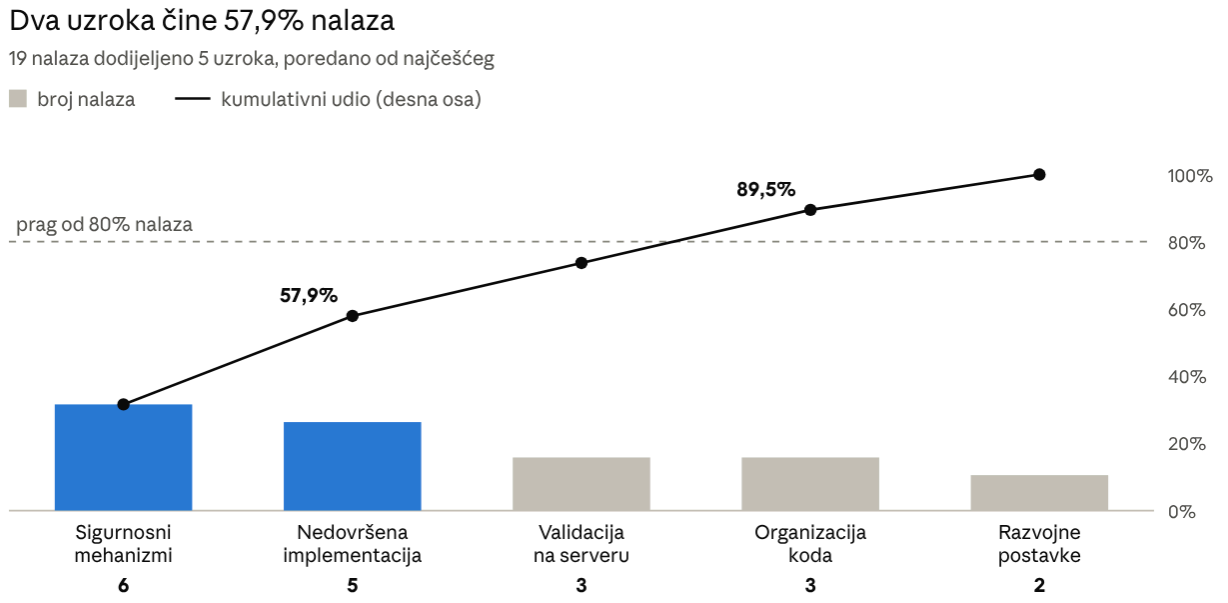
Kontrola pristupa i Struktura zajedno čine 52,6% nalaza, a prag od 80% se dostiže tek sa četiri tipa. Sva tri nalaza ozbiljnosti 5 pripadaju tipu Kontrola pristupa, pa je on ujedno i tip s najvećim uticajem.

## 5. Pareto analiza uzroka

Za svaki nalaz je određen osnovni uzrok. Dodjela uzroka je procjena tima, a ne mjerenje.

| Uzrok | Nalazi | Broj | Udio | Kumulativno |
|---|---|---|---|---|
| U1: Nedovoljna primjena sigurnosnih mehanizama (autorizacija, CSRF, tajne) | N1, N5, N7, N8, N12, N15 | 6 | 31,6% | 31,6% |
| U2: Nedovršena implementacija i ostavljen privremeni kod | N2, N10, N11, N16, N19 | 5 | 26,3% | 57,9% |
| U3: Povjerenje podacima s klijenta, validacija na serveru nedostaje | N6, N9, N13 | 3 | 15,8% | 73,7% |

| Uzrok | Nalazi | Broj | Udio | Kumulativno |
|---|---|---|---|---|
| U4: Loša organizacija koda i repozitorija | N14, N17, N18 | 3 | 15,8% | 89,5% |
| U5: Razvojne postavke ostavljene u konfiguraciji | N3, N4 | 2 | 10,5% | 100% |




Izvor: tabela nalaza N1–N19 ovog izvještaja, dodjela uzroka je procjena tima

Dva najčešća uzroka (U1 i U2) čine 57,9% nalaza, a tri uzroka 73,7%. Najvažniji uzrok je izostanak sigurnosnih mehanizama, a odmah iza njega nedovršen razvoj, što je očekivano za projekat koji je predan u radnoj verziji. Ispravljanje ova dva uzroka uklonilo bi više od polovine nalaza.

## 6. Statička analiza (Roslyn Analyzers)

Analiza je provedena nad istim kodom komandama:

dotnet build (AnalysisLevel=latest-all, EnforceCodeStyleInBuild=true),

dotnet format style,

dotnet package list --vulnerable --include-transitive.

Build je uspio bez grešaka. Log ispisuje svako upozorenje dva puta (tokom builda i u sažetku), pa je 494 pronađenih redova stvarno 247 upozorenja.

| Oznaka | Broj | Značenje | Procjena |
|---|---|---|---|
| CA2007 | 69 | ConfigureAwait | Šum, nije relevantno za ASP.NET Core |

| Oznaka | Broj | Značenje | Procjena |
|---|---|---|---|
| CA5395 | 45 | Nedostaje HTTP verb atribut na akciji | Djelimično relevantno, potvrditi |
| CA1515 | 33 | Javni tipovi mogu biti internal | Stilska preporuka |
| CS8618 | 20 | Neinicijalizovana svojstva (nullable) | Stvaran nedostatak, nizak uticaj |
| CA1062 | 18 | Argumenti javnih metoda nisu provjereni | Dio je u generisanim migracijama |
| CS8600 | 11 | Moguća null dodjela | Stvaran nedostatak, nizak uticaj |
| CA5391 | 9 | POST akcije bez antiforgery tokena | Potvrđuje nalaz N8 |

Dodatna provjera stila (dotnet format style) dala je 32 informativna upozorenja: IDE0290 (11), IDE0019 (7), IDE0060 (5), IDE0017 (4), IDE0305 (2), IDE0028 (2), IDE0090 (1).

Provjera ranjivih paketa našla je četiri tranzitivna paketa: SQLitePCLRaw.lib.e_sqlite3 2.1.11 (visoka ozbiljnost), System.Security.Cryptography.Pkcs 9.0.4 (visoka i srednja), te NuGet.Packaging i NuGet.Protocol 6.12.1 (niska).

Poređenje s ručnom inspekcijom: alat je potvrdio nalaz o POST akcijama bez tokena (CA5391 prijavljuje 9 upozorenja) i našao nalaze koje ručni pregled nije obuhvatio, a to su nullable upozorenja i ranjivi paketi. Ručna inspekcija je našla ono što alat ne može: nedostatak autorizacije, hardkodirane kredencijale, cijenu koju određuje klijent i nedovršenu funkcionalnost. Sva upozorenja alata nisu stvarne greške, jer je dio njih stilska preporuka ili šum (npr. CA2007), pa ih je trebalo procijeniti ručno.

## 7. Zaključak i preporuke

1. Dodati autorizaciju ([Authorize] i provjeru uloge) na sve kontrolere osim javnih (N5, N7, N15). To je najozbiljniji nalaz i najčešći tip defekta.
2. Svu logiku koja utiče na novac i podatke izvršavati na serveru: cijenu računati na serveru, validirati unos i dodati ValidateAntiForgeryToken na POST akcije (N6, N8, N9, N13).
3. Dovršiti započete funkcije (potvrda naloga mailom, spremanje podataka o dostavi, wwwroot i pogledi) i izbaciti privremeni kod (N2, N10, N11, N16). Kredencijale prebaciti u user-secrets ili varijable okruženja (N12).
4. Dodati .gitignore, README i ukloniti dupli kod (N17, N18, N19), te ažurirati ranjive pakete.